Checkout unavailable in production — expired TLS certificate on the payment gateway

Post-incident review · prepared by S. Hartmann (SRE) · reviewed by the Payments guild on 2026-08-04

Jira issue	INC-4830 (linked: OPS-3312 'Certificate inventory', PAY-1190)
Severity	SEV-1 — complete loss of a revenue-critical function
Environment	Production — eu-central-1, eu-west-1
Service	payments-gateway (v4.18.2), checkout-web (v11.6.0)
Detected	2026-07-28 06:12 CEST — automated (synthetic checkout probe)
Resolved	2026-07-28 07:04 CEST
Duration	52 minutes of total unavailability; 71 minutes of degradation
Incident commander	S. Hartmann · Comms: L. Reber · Ops: M. Dubois
Status	Closed — all actions completed 2026-08-19

1. What happened

At 06:12 CEST on Tuesday 28 July 2026 the public checkout flow began returning HTTP 502 for every payment authorisation request. The payments-gateway service could not open a TLS session to the acquirer endpoint `acq-gw.prod.northwind.internal` because the server certificate presented by the internal load balancer had expired at 06:11:58 CEST. Customers reaching the payment step saw a generic error page and could not complete an order. Browsing, search and basket operations were unaffected.

The outage lasted 52 minutes. Service was restored at 07:04 by installing the renewed certificate, which had been issued on 12 July but never deployed, and reloading the load balancer configuration.

2. Impact

Dimension	Measured impact
Failed checkouts	9,431 authorisation attempts rejected (100% of attempts in the window)
Customers affected	6,802 unique sessions; 148 support contacts
Revenue deferred	CHF 412,900 in basket value; CHF 48,200 estimated as permanently lost (non-returning sessions)
SLO	Monthly availability budget for checkout consumed: 71% in a single event
Regulatory	None. No card data exposed; no reportable data breach.

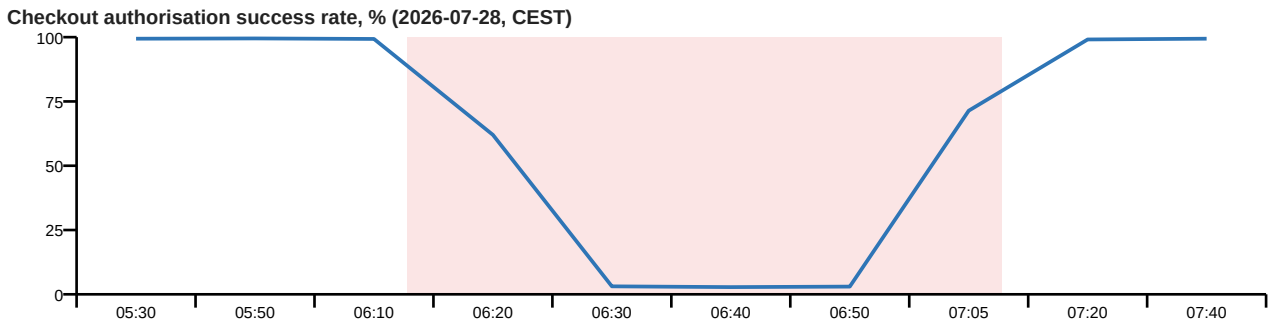

Figure 1 — shaded region is the incident window. Recovery is partial at 07:05 because eu-west-1 was reloaded four minutes after eu-central-1.

3. Timeline (all times CEST)

Time	Actor	Event
2026-07-12 09:40	cert-manager	Renewed certificate issued for *.prod.northwind.internal and written to Vault. No deployment step is triggered by issuance.
2026-07-27 18:00	—	Change freeze for the quarter-end release begins. Routine infrastructure changes are paused.

Time	Actor	Event
06:11:58	—	Certificate on lb-acq-01/02 expires.
06:12	Synthetic probe	checkout-e2e probe fails; PagerDuty alert P1-CHECKOUT-DOWN fires to the on-call SRE.
06:14	M. Dubois	On-call acknowledges. Confirms 502s in eu-central-1 and eu-west-1.
06:19	M. Dubois	Incident declared SEV-1. Bridge opened. S. Hartmann takes incident command.
06:23	S. Hartmann	Gateway logs show `x509: certificate has expired or is not yet valid`. Cause identified 11 minutes after detection.
06:31	L. Reber	Status page updated; support scripted response published.
06:38	M. Dubois	Renewed certificate located in Vault. Change freeze exception requested from the duty manager.
06:51	Duty manager	Freeze exception granted.
06:57	M. Dubois	Certificate installed on lb-acq-01/02 in eu-central-1; configuration reloaded. Success rate recovers to 71%.
07:04	M. Dubois	eu-west-1 reloaded. Success rate returns to baseline. Incident mitigated.
07:40	S. Hartmann	30 minutes of clean metrics observed. Incident closed; status page cleared.
2026-07-30 14:00	Payments guild	Postmortem review held. Actions agreed and raised in Jira.

4. Root cause

Root cause. Certificate renewal and certificate deployment were two separate processes, and only the first was automated. cert-manager issued the replacement certificate into Vault on 12 July, but nothing consumed it: the load balancers read their certificate from a file baked into the configuration bundle, which is only rewritten by a Terraform apply. No apply ran between 12 July and the expiry, so the expired certificate stayed in place. The 30-day expiry alert that should have caught this had been routed to a Slack channel that was archived in May 2026, so no human ever saw it.

Five whys

→ Checkout returned 502 — the gateway could not establish TLS to the acquirer load balancer.

→ The load balancer presented an expired certificate.

→ The renewed certificate existed in Vault but had never been deployed.

→ Deployment of a renewed certificate requires a Terraform apply that nobody runs on a schedule.

→ The expiry warning that would have prompted that apply was delivered to an archived Slack channel and was never seen.

5. Contributing factors

- The quarter-end change freeze added 13 minutes to recovery while an exception was obtained. The freeze policy did not carve out incident mitigation.
- Certificate inventory lived in a spreadsheet last updated in March 2026; lb-acq-01/02 were not on it.
- No pre-expiry synthetic check existed. Detection was by customer-facing failure, not by an early warning.

6. What went well

- Detection was automated and immediate: 2 seconds from expiry to alert.
- Diagnosis took 11 minutes from acknowledgement, because gateway TLS errors are logged verbatim rather than collapsed into a generic 502.
- Customer communication went out at 06:31, within the 30-minute commitment.

7. Action plan

Jira	Action	Type	Owner	Due	Status
OPS-3312	Build an automated certificate inventory from live TLS endpoints, refreshed daily, replacing the spreadsheet.	Prevent	M. Dubois	2026-08-15	Done
OPS-3313	Make the load balancers read certificates from Vault at reload time so that renewal and deployment are one step.	Prevent	M. Dubois	2026-08-29	Done
OPS-3314	Re-route all certificate expiry alerts to the SRE PagerDuty service; add an ownership check that fails if the destination channel is archived.	Detect	S. Hartmann	2026-08-08	Done
OPS-3315	Add a synthetic probe that fails when any production certificate is within 21 days of expiry.	Detect	A. Novak	2026-08-14	Done
PAY-1190	Return a specific, retryable error to checkout-web on acquirer TLS failure instead of a bare 502.	Mitigate	T. Iversen	2026-08-19	Done
GOV-221	Amend the change freeze policy to exempt changes made under an open SEV-1 or SEV-2 incident.	Process	R. Bianchi	2026-08-19	Done

Sign-off: R. Bianchi (Head of Platform), 2026-08-05. All six actions verified complete on 2026-08-19.